7.2.1 Effect: what the policy does

Every Cedar policy has an explicit effect: It either `permits` or `forbids` an action.

Most policies are written to grant access, meaning they permit access under specific conditions. However, Cedar also supports explicit forbid policies, which let authors set rules to deny access. A policy that forbids always overrides one that permits. This makes it simpler to enforce constraints like "never allow access to confidential documents from unmanaged devices," even if a permit policy might normally apply.

At ACME Corp, for instance, the identity team uses both types of policies:

- A `permit` policy may allow engineers to deploy code from managed devices.
- A `forbid` policy might prevent deployments altogether outside of business hours for junior engineers, even if they're on call.

The effect is always the first thing a Cedar policy states, and it determines whether the policy contributes a yes or a no to the overall decision.

7.2.2 Scope: when the policy applies

The scope of a policy specifies the who, what, and where of an access request:

- **Principal**: who is making the request
- **Action**: what operation they are trying to perform
- **Resource**: which objects the action targets

In Cedar, these are included in the policy header. The engine uses them to quickly determine which policies are relevant to a specific request.

Think about ACME's Customer Collaboration platform. A policy might be scoped like this:

- **Principal**: any employee